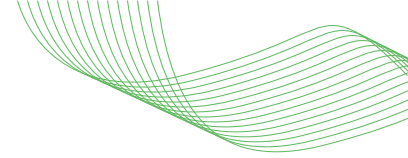




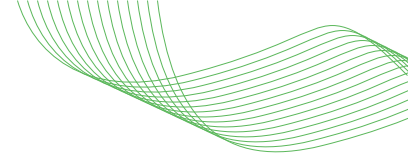
AIMM: Artifact Integrity Maturity Model for AI/ML Supply Chain Trust and Provenance

Workstream 1: Software Supply Chain Security for AI Systems



Contents

AIMM: Artifact Integrity Maturity Model for AI/ML Supply Chain Trust and Provenance	2
Table of contents	2
1. Introduction	3
2. Rationale for an Artifact Integrity Maturity Model	3
3. Key Terms and Definitions: AI/ML Supply Chain	4
Technical Terms	4
Roles	5
4. Practical Application: Selecting Artifact Maturity Levels by Use Cases	6
5. Maturity Levels	7
5.1 Maturity Level 1: Basic Artifact Integrity	7
Intent	7
Benefits	7
Implementation Approach	7
Limitations	8
5.2 Maturity Level 2: Provenance and Lineage	8
Intent	8
Benefits	9
Implementation Approach	9
Limitations	11
5.3 Maturity Level 3: Structured Attestations for Policy Automation	11
Intent	11
Benefits	11
Implementation Approach	12
Limitations	13
6. Conflicting Claims and Multi-Party Claim Reconciliation	14
7. Agent Considerations	15
8. Incremental Adoption Strategies	15
9. Scope and Boundaries	16
10. Ecosystem context	16
11. Conclusion	16
12. Sources	17
13. Contributors and Acknowledgements	17
14. Appendix	18
14.1 CoSAI Focus	18
14.2 Guidelines on usage of more advanced AI systems (e.g. large language models (LLMs), multi-modal language models. etc) for drafting documents for OASIS CoSAI:	18
14.3 Disclaimer	19
14.4 Copyright Notice	19



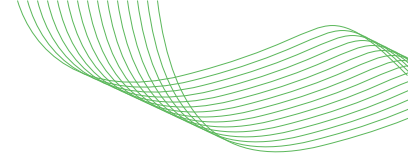
AIMM: Artifact Integrity Maturity Model for AI/ML Supply Chain Trust and Provenance

OASIS Open Project : Coalition for Secure AI (CoSAI) Workstream 1: Software Supply Chain Security for AI Systems

Approved by the CoSAI Project Governing Board on 07 September 2026

Table of contents

- AIMM: Artifact Integrity Maturity Model for AI/ML Supply Chain Trust and Provenance
 - 1. Introduction
 - 2. Rationale for an Artifact Integrity Maturity Model
 - 3. Key Terms and Definitions: AI/ML Supply Chain
 - * Technical Terms
 - * Roles
 - 4. Practical Application: Selecting Artifact Maturity Levels by Use Cases
 - 5. Maturity Levels
 - 5.1 Maturity Level 1: Basic Artifact Integrity
 - * Intent
 - * Benefits
 - * Implementation Approach
 - * Limitations
 - 5.2 Maturity Level 2: Provenance and Lineage
 - * Intent
 - * Benefits
 - * Implementation Approach
 - * Limitations
 - 5.3 Maturity Level 3: Structured Attestations for Policy Automation
 - * Intent
 - * Benefits
 - * Implementation Approach
 - * Limitations
 - 6. Conflicting Claims and Multi-Party Claim Reconciliation
 - 7. Agent Considerations
 - 8. Incremental Adoption Strategies
 - 9. Scope and Boundaries
 - 10. Ecosystem context
 - 11. Conclusion
 - 12. Sources
 - 13. Contributors and Acknowledgements
 - 14. Appendix
 - * 14.1 CoSAI Focus
 - * 14.2 Guidelines on usage of more advanced AI systems (e.g. large language models (LLMs), multi-modal language models. etc) for drafting documents for OASIS CoSAI:
 - * 14.3 Disclaimer
 - * 14.4 Copyright Notice



1. Introduction

Machine learning models have become integral components of modern infrastructure, from autonomous vehicles and medical diagnostics to financial algorithms and enterprise applications. This pervasive adoption brings a corresponding responsibility: ensuring that these systems can be trusted, that their origins can be verified, and that their integrity can be guaranteed throughout their lifecycle.

In our previous paper, *Signing ML Artifacts: Building towards tamper-proof ML metadata records*, we introduced the foundational concepts of model signing and established the case for cryptographic protection of machine learning artifacts. That work defined the core mechanisms through which model producers create tamper-proof claims and model consumers verify those claims before deployment. It outlined the personas involved, the technical foundations of signing, and provided a brief introduction to the concept of maturity levels.

This paper expands on that foundation. Where the first paper established why model signing matters and what it entails, this paper addresses how organizations should approach implementation across varying levels of sophistication, capability, and risk tolerance. The maturity model presented here, the Artifact Integrity Maturity Model (AIMM), provides a structured pathway from basic artifact protection to comprehensive attestation systems capable of supporting automated policy enforcement and regulatory compliance.

The framework is not a one-size-fits-all prescription. A startup deploying its first production model faces fundamentally different challenges than a multinational financial institution managing hundreds of models across regulated jurisdictions. A research organization sharing open-source models operates under different requirements than an industrial robotics manufacturer building autonomous systems. Recognizing this diversity, the AIMM offers actionable maturity levels tailored to different needs and capabilities. Each level provides concrete security and governance benefits while establishing the foundation for model robustness and scalability. This paper provides organizations with the necessary tools to assess their current state, identify appropriate targets based on their risk profiles and regulatory requirements, and chart incremental paths toward enhanced capabilities.

The framework's maturity levels provide guidance for both model consumers and model providers across the AI/ML supply chain. For model producers—those who train, fine-tune, and publish models—it provides guidance on signing artifacts effectively, what claims to make, and how to strengthen security posture. For model consumers—those who download, verify, and deploy models—it provides guidance on verification practices, trust policies, and interpretation of signed claims. This dual perspective reflects the reality that the same organization may simultaneously act as consumer (using foundation models) and producer (creating fine-tuned derivatives).

This target audience for this paper includes security practitioners, AI/ML engineers, compliance teams, and executive leadership.

2. Rationale for an Artifact Integrity Maturity Model

AI/ML artifacts increasingly move through distributed supply chains in which models, datasets, configurations, and process artifacts are created, transformed, and deployed across multiple teams and environments. In that context, organizations need a structured way to express different levels of assurance depending on risk, scale, and governance requirements. A maturity model provides that structure by mapping controls to progressively stronger trust guarantees.

This structure also reflects the direction of AI governance. Regulatory frameworks such as the EU AI Act and the NIST AI Risk Management Framework increasingly expect organizations to understand their AI/ML dependencies, manage risks across the lifecycle, and maintain evidence

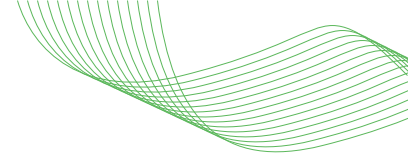
that supports audit, incident response, and accountable deployment. In parallel, software supply chain initiatives such as SLSA, the in-toto Attestation Framework, and Software Bill of Materials approaches have established patterns for artifact integrity, provenance, and attestations in traditional software ecosystems. AIMM builds on these complementary ideas while focusing specifically on the AI/ML artifact lifecycle, where models, datasets, transformations, and derived artifacts introduce additional provenance and verification requirements.

By framing artifact integrity as a maturity model, AIMM provides an incremental adoption path that lets organizations apply stronger controls as risk, scale, and governance needs increase. This gives producers, consumers, and governance stakeholders a shared language for comparing assurance levels and planning adoption.

3. Key Terms and Definitions: AI/ML Supply Chain

Technical Terms

Term	Definition	Sources
Admission gating	The mechanism that checks whether artifacts satisfy policy requirements before reaching deployment targets.	<i>This framework</i>
Artifacts	Immutable digital objects produced by a process, such as binaries, datasets, or models.	[3][9]
Attestations	Cryptographically signed claims about artifacts, conforming to a defined format specification.	[3][9]
Authenticity	Assurance that an artifact originates from a genuine source and that this origin can be verified.	[1][4][7]
Claims	Asserted facts or properties about an artifact, including its integrity, lineage, or provenance.	[1][2]
Integrity	Assurance that an artifact has not been altered or tampered with.	[4][7]
Lineage	Chain of transformations that describe the history of the artifact.	[8]
Model signing	Cryptographic mechanism that binds a model artifact to an identified producer, enabling consumers to verify integrity and authenticity.	[1][6][10]



Term	Definition	Sources
Policy engine	Evaluates attestations, lineage metadata, and deployment context against a policy, returning a deployment decision.	[5]
Provenance	A documented single transformation in the larger supply chain where input artifacts produce new output artifacts.	[3][8][9]
Signature	Cryptographic binding of data to a signer.	[6][9]
Transformation	Any process that acts on a model artifact to produce a new model artifact, such as training, fine-tuning, quantization, distillation, or compression.	[8][10]

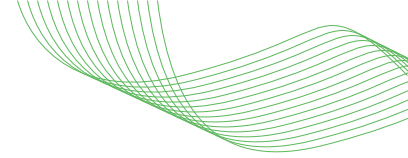
Roles

Roles introduced in the first CoSAI WS1 paper [10]:

Role	Definition	Sources
Model consumer	Entity who verifies and uses a model.	[9][10]
Model producer	Entity who creates or transforms, signs, and publishes a model.	[8][10]

Roles introduced in this paper:

Role	Definition	Sources
Attester	Entity that produces a signed statement about a specific artifact, conforming to a defined predicate type; introduced at Level 2.	[2][9]
Signer	Entity that signs artifacts or attestations, binding the artifact to a verifiable identity.	[6]
Verifier	Entity that validates signatures at all levels, attestations, and claims against trust policies before permitting an artifact to proceed.	[2][9]



4. Practical Application: Selecting Artifact Maturity Levels by Use Cases

Building on the three maturity levels introduced in the first paper*: Basic Artifact Integrity, Provenance and Lineage, and Structured Attestations for Policy Automation, this section examines these levels through a practical lens that centers typical use cases.

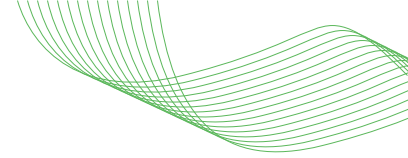
AI artifacts such as models, training data, and configurations require different levels of trust assurance depending on their deployment context and risk profile. Each AIMM maturity level answers progressively deeper trust questions: “Is this artifact authentic?” (L1), “Where did it come from?” (L2), and “Does it meet specified policies?” (L3). This progression helps organizations select appropriate controls based on business requirements and risk tolerance rather than technical capabilities alone.

Level	The Question	Intended For	What's Verified	Integration Complexity
1	“Is this model what it claims to be?”	Developers, startups, research teams establishing baseline security	Artifact integrity and producer authenticity (who signed, when, content unchanged)	Lightweight - at well-defined release and consumption boundaries
2	“Where did this model come from?”	Organizations with multi-party supply chains, managing derived models	Provenance and lineage (parent models, data sources, transformations, derivation relationships)	Moderate - requires pipeline integration and parent artifact access, multi-party coordination
3	“Does this model comply with specified policies and industry standards?”	Regulated industries, high-stakes applications, scaled operations	Policy compliance via attestations (process controls, quality metrics, regulatory requirements)	Complex - management of structured attestation formats and storage, policy engines

Each level builds upon the previous one’s capabilities while addressing increasingly sophisticated supply chain risks. Organizations may apply different levels to different use cases based on risk tolerance and deployment context. For example, a healthcare organization might require AIMM Level 3 controls for clinical diagnostic models, while using Level 1 for internal research or exploratory experimentation. **The levels represent capability progression, not organizational maturity.** Teams can selectively implement higher levels for critical use cases while maintaining simpler approaches elsewhere.

However, when implementing controls specific to higher AIMM levels, to achieve those levels holistically, organizations will implement lower level controls ensuring inheritance of all lower-level capabilities: Level 2 implementations include Level 1’s integrity guarantees plus provenance and lineage tracking, while Level 3 provides the full spectrum of integrity, lineage, and custom attestations.

*Some levels have been slightly renamed from the previous whitepaper to more precisely reflect their intent.



5. Maturity Levels

5.1 Maturity Level 1: Basic Artifact Integrity

AIMM Level 1 represents the adoption of model signing including model signing verification and validation, focusing on artifact integrity and model producer authenticity claims. In other words, signing serves to cryptographically bind a model artifact to an identified claimant producer at a specific point in time in the model's lifecycle.

Intent

For the purposes of this paper, model artifacts include: models (foundation, fine-tuned, quantized), data artifacts (training and evaluation datasets, preprocessing pipelines), and process artifacts (training scripts, configurations, hyperparameters). In environments where model artifacts are distributed across teams, shared through public hubs, or incorporated into automated deployment pipelines, an adversary may modify the model artifact between lifecycle stages, before the model is uploaded to a hub, or deployed. By signing the model artifact itself and implementing a mechanism for signature validation/verification, Level 1 enables model consumers to detect threats such as model tampering and check that a model came from a particular producer. Assuming the provider is running a controlled and monitored signing ecosystem with verified key integrity and no indicators of control loss, this integrity, with respect to the artifact as signed, is guaranteed; any change to the bits *verifiably* invalidates the signature.

Benefits

AIMM Level 1 establishes a baseline of trust:

- **Artifact tamper detection:** Strong detection of model tampering, accidental corruption, and many classes of supply-chain attacks, including model substitution and registry compromise.
- **Verifiable model authenticity:** A clear signal that a model is exactly the artifact the producer intended to distribute and that it originates from a known identity.

Implementation Approach

Model producers implement AIMM Level 1 using cryptographic techniques designed to protect the integrity and authenticity of a model artifact as follows. Implementation considerations such as PKI and certificates are discussed in the earlier CoSAI WSI paper, *Signing ML Artifacts*.

- **Computing a cryptographic hash** (for example, SHA-256) over the complete model artifact, typically treating all files that constitute the model as a single logical unit.
- **Digitally signing the hash** using a private key held by the model producer, creating a digital signature that binds the model's exact contents to the producer's identity.

Consumers verify the model signature by:

- **Recomputing the hash** over the received artifact, and
- **Validating the signature** with the producer's public key.

Interpreting Level 1 verification results: Any modification to the model—whether a single flipped bit or a partial file replacement—breaks the hash verification step, providing a clear and unambiguous signal that integrity was broken. Failed signature validation calls into question the producer's authenticity.

Integration into workflows: Integration at Level 1 is intentionally lightweight:

- **Producers** should sign model artifacts at a well-defined release boundary, such as the end of training, fine-tuning, or packaging, when the model artifact is considered immutable and ready for distribution.
- **Consumers** should verify model signatures upon downloading a model artifact from its distribution channel to ensure that unsigned or invalidly signed models are rejected before they are input into an ML pipeline or reach production.

Limitations

- Verifiers / consumers need access to the original model artifact to recompute its hash.
- Model signatures provide only single point-in-time snapshots of model integrity, so AIMM Level 1 does not address tampering that occurs *during* model transformations.

5.2 Maturity Level 2: Provenance and Lineage

AIMM Level 2 focuses on lineage tracking and provenance verification. Rather than signing and verifying/validating artifacts in isolation, organizations create cryptographically verifiable chains that attest to relationships between artifacts and the processes that connect them.

Intent

In environments where models undergo multiple transformations (fine-tuning, quantization, distillation) across teams or organizations, the integrity of a single artifact is insufficient. An adversary or an honest mistake at any upstream step can propagate undetected if consumers can only verify the final artifact in isolation. When a vulnerability is discovered in a foundation model, organizations without lineage tracking cannot efficiently determine which downstream models inherited the issue.

By signing not only model artifacts but also attesting to their derivation from other signed artifacts, consumers can answer: “Where did this artifact come from, and what transformations produced it?” Without signatures, provenance metadata would be mere documentation, easily forged. Model provenance attestations become verifiable evidence. Consumers verify not only that Model Y claims to derive from Model X, but that this claim was made by an identified party whose signature validates the assertion.

MODEL PROVENANCE VS. MODEL SIGNING

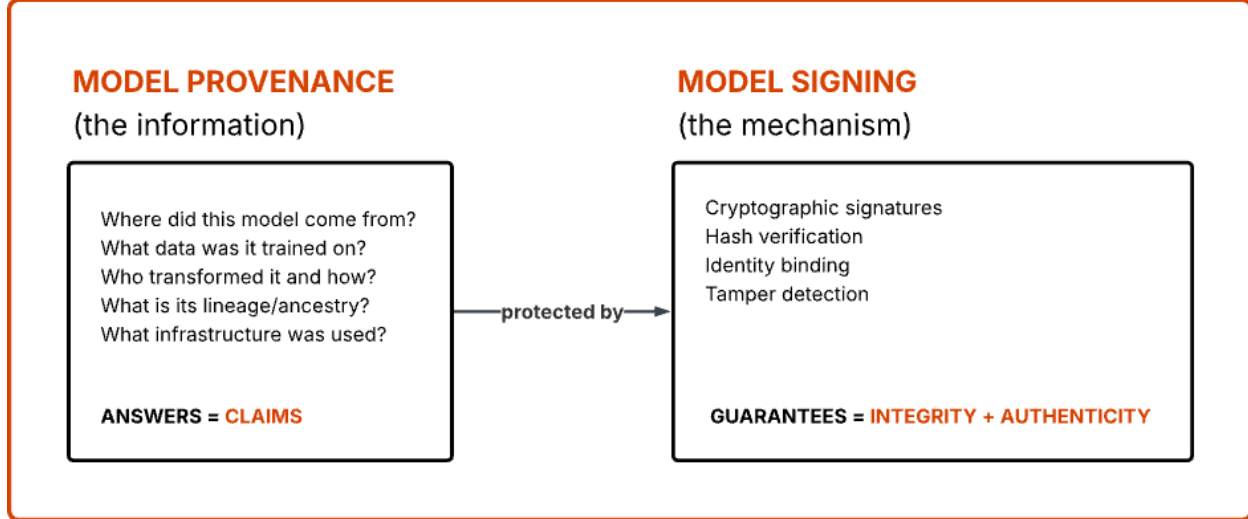


Figure 1: Model Provenance and Model Signing

Benefits

AIMM Level 2 builds upon the Level 1 baseline of trust to provide additional benefits:

- **Enhanced vulnerability triage:** When a vulnerability is discovered in a foundation model, organizations with model provenance attestations and lineage tracking can more quickly identify which deployed models inherited it, accelerating incident response and limiting exposure.
- **Audit-ready compliance:** Emerging AI regulations increasingly require documentation of model origins, training data sources, and development processes. Signed, tamper-proof provenance records serve as audit evidence for AI/ML artifacts.
- **Multi-party accountability:** When multiple parties contribute to a model's development, provenance attestations clearly attribute each contribution, establishing who performed what transformations and directing allocation of responsibility when issues arise.
- **Foundation for policy enforcement:** The provenance and lineage tracking infrastructure established at Level 2 prepares organizations for more general, structured attestations and automated policy enforcement at higher AIMM levels.

Implementation Approach

Model producers implement AIMM Level 2 by attesting to derivation relationships and transformation processes alongside the artifacts themselves.

Provenance attestations

Model producers implement Level 2 by generating signed provenance claims, i.e., provenance attestations, in addition to Level 1's model artifact signatures:

- Provenance attestations are encoded in structured data formats produced by identified attesters (e.g., JSON using standards like in-toto attestations, YAML).
- These attestations accompany the model as detached signature bundles, embedded within packages, or stored in registries. They can include: derivation claims (one artifact derived

from another), verification claims (an input was authenticated before use), evidence-backed provenance claims (the transformation process is documented), and transitive derivation claims (multi-step transformations chained together).

- Provenance attestations may additionally include contextual metadata associated with lineage-relevant transformations, such as workflow identifiers, transformation references, or related execution context associated with the transformation process or environment. Such references can help consumers interpret provenance claims in distributed or multi-party workflows without elevating these records to the full infrastructure or process attestations described in Level 3 (see Section 5.3).

Example claim formats and implementation patterns are provided in companion technical guides. See the CoSAI WSI repository for the latest companion materials.

Lineage tracking through signature chaining

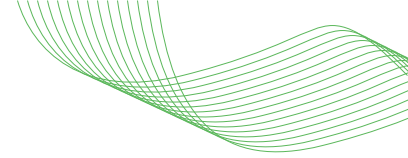
Model producers track model lineage when a derived artifact (e.g., a fine-tuned model) is created from a signed parent artifact (e.g., a foundation model) by signing the derived artifact together with claims that reference the parent artifact's signature or provenance attestation, typically via the parent's cryptographic hash. This parent-child linkage can extend transitively across multiple generations, creating an auditable chain of custody.

Model producers can choose to link signed artifacts and provenance attestations in different topologies, from simple chains for version history to full graphs for complex scenarios like model ensembles. A complete Level 2 record for a fine-tuned model might document the base model, dataset, fine-tuning script, and configuration with verifiable derivation claims.

Consumers verify provenance and lineage by:

- **Performing baseline checks** on attestation signature validity, signer identity against trust stores, and a proof that each signature is recent and non-replayable by enforcing trusted timestamping or short-lived certificate issuance. Baseline checks confirm that the model is authentic, traceable, and unchanged which includes a fully intact chain of custody from creation to deployment.
- **Traversing lineage** by validating signatures on all parent artifacts referenced in provenance attestations, following the organization's chosen topology (e.g., chain, tree).
- **Confirming artifact integrity** to ensure that artifact hashes recorded in each provenance attestation match hashes computed from actual artifacts, ensuring consistency between claims and reality.
- **Validating derivation consistency** to confirm that derivation claims are internally consistent (e.g., a quantized model claims derivation from an architecturally compatible parent and the transformation process is documented).
- **Cross-checking multi-party attestations** when multiple parties contribute signatures to an artifact's lineage, validating that each party's claims are authentic and mutually consistent.

Integration into workflows: Integration into workflows can be adopted incrementally based on organizational maturity and risk tolerance. **Producers** should begin by signing the most critical lineage relationships, such as the link between a fine-tuned model and its foundation model, while initially omitting dataset and process signatures and adding complexity over time. **Consumers** should verify provenance chains upon artifact ingestion, using verification libraries that provide clear pass/fail results.



Limitations

- Provenance and lineage tracking have considerable operational implications. Organizations must decide whether to distribute full parent artifacts, only signatures and attestations, or rely on external registries, each presenting trade-offs between bandwidth requirements, verifiability guarantees, and infrastructure dependencies. As the amount of collected provenance information grows, model lifecycle management becomes a first-class operational concern, including versioning, synchronization with artifacts, and registry consistency.
- Complex provenance topologies and multi-signature validation introduce greater verification complexity than single-signature checks.
- AIMM Level 2 establishes *what* transformations occurred but does not enforce whether those transformations met organizational policies or quality standards. Automated policy enforcement requires a wider set of structured attestations, covered at the next maturity level.

5.3 Maturity Level 3: Structured Attestations for Policy Automation

Intent

AIMM Level 3 is intended as the north star of AI artifact integrity and may complement control frameworks such as the CoSAI Risk Map (CoSAI-RM). Level 3 captures rich, structured information about model development processes, properties, and compliance status. Building on Level 2's verifiable lineage, Level 3 enforces, automatically and through cryptographic evidence, that artifacts meet specified organization policies and industry standards at different phases of the model development lifecycle, before they enter production. This is verified through attestations that conform to defined predicate schemas as detailed below.

The risks AIMM Level 3 targets differ from those at Levels 1 and 2: compliance and governance risks, i.e., failure to evidence policy adherence, internal standards, or regulatory obligations in an automated, audit-ready manner. Where lower AIMM levels protect what was produced, Level 3 ensures that what is deployed has been evaluated against organizational policy and external regulation without manual review.

Level 3 generalizes the concept of attestations introduced at Level 2: Where Level 2 attestations are signed claims about artifact relationships and derivation, Level 3 attestations are structured claims produced by identified attesters, containing model development lifecycle information. Because these attestations conform to defined predicate schemas that enable machine evaluation, a policy engine can parse and evaluate attestations against encoded organization-specific rules, which is not possible with provenance and lineage alone.

We note that AIMM Level 3 is not universally necessary. It is most relevant for regulated industries, high-stakes applications, complex multi-party supply chains, and environments requiring automated governance at scale. For these contexts, Level 3 provides the infrastructure to move from trust-by-convention to trust-by-evidence.

Benefits

AIMM Level 3 amplifies the incident-response and compliance benefits of Level 2.

- **Evidence-backed incident response:** When a vulnerability surfaces, attestation records reveal not only which models are affected but what evaluations were conducted, what data was used, and whether existing controls should have detected the issue.
- **Continuous compliance evidence:** Compliance evidence is generated continuously as a byproduct of normal operations rather than reconstructed reactively at audit time. Each

deployment produces an evidence chain that maps directly to frameworks such as the EU AI Act, NIST AI RMF, and ISO/IEC 42001.

- **Preventive control:** The defining benefit of Level 3. Unsigned, unattested, or non-compliant artifacts can be blocked before reaching production, not flagged after.

Implementation Approach

The core mechanism is the attestation: a signed statement by an identified party (the *attester*) about a specific artifact, conforming to a defined predicate type. Admission gating turns the attestation from evidence into control. The in-toto Attestation Framework, which has seen wider adoption for software supply chain integrity, may be a suitable option for implementing AIMM Level 3 in the model lifecycle as well. Specific predicate types and required fields are defined in companion design documents.

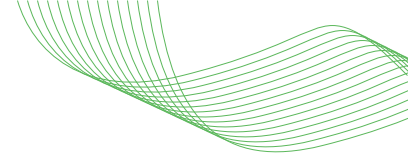
AIMM Level 3 organizes attestations into four conceptual categories:

- **Model attestations** capture a model's characteristics: evaluation metrics, quality, fairness assessments, safety benchmarks, and behavioral properties. Because model behavior cannot be determined through inspection, these attestations record evaluation results that consumers can trust based on the attester's identity.
- **Data attestations** document dataset provenance, characteristics, and compliance status: source, collection methodology, preprocessing, PII scanning, licensing, statistical properties. They carry particular regulatory weight under frameworks like the EU AI Act.
- **Process attestations** document how an artifact was produced: pipeline identity, build environment, configuration, and input artifacts. They mitigate risks of source tampering and pipeline compromise. Process attestations may additionally reference integrity evidence for external resources, artifacts, services, or third-party dependencies accessed during transformation workflows, including remotely retrieved datasets, model artifacts, APIs or auxiliary tooling whose behavior or outputs materially influenced the resulting artifact.
- **Infrastructure attestations** document the security properties of the production environment, including hardware platforms (e.g., CPUs, GPUs, accelerators), security controls, and hardware attestation reports. In environments where models are trained or served within Trusted Execution Environments (TEEs) such as Intel TDX or AMD SEV-SNP, infrastructure attestations can include hardware-rooted evidence that the compute environment has not been tampered with, binding the attestation to a hardware root of trust rather than relying solely on software-level claims.

In practice, AIMM Level 3 implementations may operate across heterogeneous attestation and policy validation environments, requiring interoperability across multiple trust sources, registries, verification workflows, and deployment environments. Level 3 attestations are contributed by multiple parties: model producers, infrastructure or cloud service providers, validation teams, security teams, data governance teams, each signing claims within their area of responsibility.

Verification through Policy Automation. The defining capability of AIMM Level 3 is automated policy enforcement, which makes the multi-party attester model tractable: the policy engine absorbs the complexity of collecting, cross-referencing, and validating claims from many attesters. Rather than relying on human reviewers to inspect attestations and make deployment decisions, Level 3 organizations encode their trust requirements as machine-evaluable policies and enforce those policies through automated gates in the deployment pipeline.

A policy engine evaluates an artifact's attestations, lineage metadata, and deployment context against a policy, returning a decision (typically PASS, WARN, or FAIL). The evaluation is itself



recorded as a signed claim. A minimal policy includes three foundational rules—artifact integrity (Level 1), lineage verification (Level 2), and attestation validity (Level 3)—extended with the organization's domain-specific rules such as minimum evaluation thresholds, fairness metrics, data licensing checks, or infrastructure security requirements. Policy evaluation feeds into admission gating, the mechanism that prevents non-compliant artifacts from reaching deployment targets.

Admission gating is the enforcement layer that operationalizes attestations and turns the structured, predicate-based attestations from evidence to controls. With admission gating, attestations are mandatory inputs to decisions, policy is evaluated automatically and consistently, and non-compliant artifacts are blocked before impact. Without admission gating, attestations are advisory only; with it, Level 3 achieves a preventive control posture.

At Level 3, consumers verify attestation validity by:

- **Verifying attestation signatures** against trusted attester identities
- **Confirming required attestation types** are present
- **Validating that the policy engine produced a passing decision** against the applicable policy
- **Ensuring the policy and present attestations are in compliance** with internal and external requirements
- **Confirming an admission decision** for deployment-targeted artifacts.

Together, these verifications enable model consumers to answer the AIMM Level 3 trust question with cryptographic confidence: this model meets organization policies and industry standards, evidenced by signed attestations from trusted parties, evaluated against our encoded policies, and admitted through our deployment gates.

In multi-party or long-lived supply chains, policy evaluation results and associated attestations may need to remain portable and independently verifiable outside the original producing environment, including across organizational boundaries, deployment targets, regulatory audits, or archival retention periods. Organizations should therefore consider persistence and portability requirements, and by extension interoperability and distribution, when designing attestation storage and verification workflows.

Integration into workflows: Level 3 integration requires coordination across multiple organizational functions:

- **Producers** integrate attestation generation into training and evaluation pipelines, ensuring that process, model, and data attestations are generated automatically as part of standard workflows rather than added manually after the fact.
- **Consumers** validate policy evaluation results at artifact ingestion, rejecting artifacts that lack required attestation categories or that failed policy evaluation.
- **Operators** implement admission gating as part of production infrastructure with defined failover behavior, escalation paths, and break-glass procedures for when the policy engine is unavailable.

Limitations

- Policy enforcement is only as strong as the policies themselves. A permissive or incomplete policy will admit artifacts that should be rejected. Policy governance (versioning, review, testing, and periodic reassessment) is a first-class operational concern.

- The attestation, policy-engine, and admission-controller infrastructure carries significant computational and organizational overhead. Organizations should ensure the investment is justified by their risk profile.
- Fully automated policy enforcement remains an aspirational approach at the time of initial release of AIMM. Many schemas for structured attestations capable of capturing domain-specific compliance metrics, and generic model or infrastructure attributes, either do not exist yet or have not undergone rigorous legal and standardization scrutiny, because of the complexity of making the required information machine-readable. Therefore, organizations implementing AIMM Level 3 will likely need to start by adopting a hybrid approach that combines automation together with manual peer-review for difficult-to-automate policy checks, and transition to increasingly automated artifact integrity as the attestation and infrastructure ecosystems mature.
- Cross-cutting limits that apply at every maturity level (e.g., runtime behavioral risks, compromised signing or attestation infrastructure, training-time risks that leave no artifact trace) are addressed in the Scope and Boundaries section of this paper.

6. Conflicting Claims and Multi-Party Claim Reconciliation

In production environments, multiple sources of truth may exist for the same artifact. For example, a model might have pipeline-generated lineage records (Level 2), automated policy evaluation results (Level 3), and independent audit checks (Level 1) all referring to the same artifact.

Verifiers must reconcile these conflicting claims through systematic approaches:

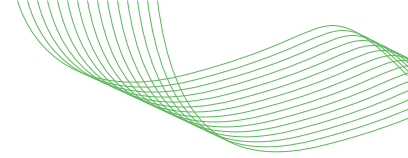
Role-based validation: The responsible party or organization's verification policy must define which roles are authorized to produce which types of claims. Each attester's claims are validated against these role-to-claim-type mappings. Claims produced outside a party's authorized responsibilities are rejected.

Completeness reviews: Required attestations must be present and valid, while missing recommended attestations generate warnings but may still allow use with documented gaps.

Consistency checks: When multiple parties independently verify the same artifact (e.g., computing hashes), their results must match. The verification process must collect and compare results from each party, either through a shared transparency log, where all parties publish their verification records, or through a centralized verifier that gathers results before issuing a final determination. Mismatched results indicate the artifact changed between measurements and trigger immediate verification failure.

Conflict resolution: Organizations should define policies for handling legitimate conflicts. Examples may include:

- **Strict:** Any conflict fails verification (high-security environments)
- **Majority rule:** Most trusted parties win (distributed scenarios)
- **Hierarchy:** Higher authority or more recent claims win
- **Latest wins:** Most recent valid claim supersedes older ones



7. Agent Considerations

As AI agents increasingly consume, transform, and deploy model artifacts autonomously, they must participate in the signing and verification ecosystem as first-class entities rather than transparent intermediaries. The principles below extend the maturity framework to agentic contexts and align with the CoSAI Agentic Identity and Access Management framework, where applicable.

Agent identity and artifact binding. When an agent downloads, fine-tunes, or deploys a model, the agent's identity should be cryptographically bound to the action. At Level 1, this means the agent verifies signatures before loading any artifact. At Level 2, the agent's transformation of an artifact (such as quantization or distillation) should produce a new provenance attestation that references both the parent artifact and the agent's identity. At Level 3, agents should carry structured attestations that include their code hash, model version, and configuration, enabling downstream verification that the agent performing the transformation was itself authenticated and authorized.

Reconciliation and conflict handling. Agent-generated claims follow the same role-based validation as human-generated ones and must operate within their designated organizational scope. Agents should be configured with clear policies for handling conflicts, either failing safely when claims conflict or escalating to human oversight.

Delegation and scope constraints. When orchestrator agents delegate artifact operations to sub-agents (for example, delegating model evaluation to a specialized testing agent), the scope of signing authority should narrow at each delegation hop and must not expand beyond the delegating principal's permissions. This mirrors the delegation model defined in the CoSAI Agentic IAM framework, where scope narrows and revocation cascades through the chain. In dynamic or long-running workflows, delegated authority may additionally be bound to specific tasks, execution contexts, or runtime conditions to reduce credential reuse outside the intended operational scope.

Hardware-backed agent attestation. In TEE-enabled environments, agent runtime attestation can be rooted in hardware measurements, providing evidence that the agent's execution environment has not been modified. This creates a verifiable link between the artifact's attestation chain and the agent's runtime integrity, strengthening the end-to-end trust model from silicon to deployment. See the CoSAI Agentic IAM paper and the CoSAI MCP Security paper for detailed attestation flow patterns and protocol-level security guidance.

Runtime execution provenance for agentic systems.

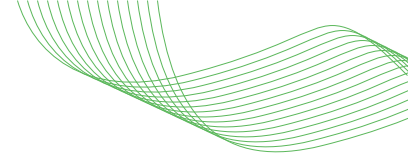
In autonomous or multi-agent systems, provenance may extend beyond static artifact lineage to include runtime activities and execution-state transitions associated with workflow execution, such as delegated actions, tool invocations, retrieved context, external resources, credentialing and inter-agent communication. Because these interactions may be ephemeral, dynamically determined and/or distributed across execution boundaries, organizations may require additional provenance records to preserve traceability and accountability relationships across distributed agent-driven environments. These runtime provenance records complement the attestation and policy automation mechanisms described in AIMM Level 3.

8. Incremental Adoption Strategies

For most organizations today, the starting point is zero: no models signed, no verification performed. Moving from this baseline requires a phased approach that prioritizes high-impact use cases.

Recommended adoption sequence:

- Start with Level 1 on highest-risk models. Identify models carrying the greatest conse-



quences of compromise—for example, those that are production-deployed, externally-facing, or under regulatory scrutiny—and implement signing and verification for these first. Prioritize externally-sourced models where integrity risk is highest.

- Expand Level 1 coverage to additional models, guided by risk-based prioritization.
- Introduce Level 2 when encountering models with complex derivation histories (fine-tuned, distilled, or multi-source models) where verifying the provenance chain materially strengthens security posture.
- Defer Level 3 until the organization has both a clear policy requirement (regulatory or internal) and the attestation infrastructure to support it. Premature Level 3 adoption imposes significant complexity without proportionate benefit if the policy framework is not yet defined.

Handling unsigned external models: Most externally-sourced models are currently distributed without signatures. Organizations can adopt a re-signing policy at ingestion: download the unsigned model, perform feasible integrity checks, then sign it with the organization's own key before admitting it to internal registries. This does not match an end-to-end producer signature, but establishes a signed trust boundary from that point forward.

Key management foundations underpin all adoption strategies. Signing keys must be protected from unauthorized access, trust stores curated, and rotation and revocation procedures defined before they are needed.

9. Scope and Boundaries

Model artifact signing and attestation provides integrity (artifact not modified) and authenticity (signer identity verified). It does not guarantee correctness, safety, fairness, or benign behavior of the signed artifact itself. Runtime behavioral threats, compromised signing infrastructure, and training-time attacks that leave no artifact trace remain outside the scope of signing. Level 3 attestations narrow these gaps but do not close them entirely. Organizations should adopt model signing and attestation as layers within a defense-in-depth strategy, complemented by behavioral testing, runtime monitoring, and independent audits.

10. Ecosystem context

Several cross-industry initiatives and open-source projects provide foundational capabilities for implementing the maturity levels described in this paper. Organizations such as OWASP, NIST, OpenSSF, C2PA and CoSAI Workstreams 2-4 provide complementary software/model security frameworks and tools. For instance, MITRE ATLAS provides a comprehensive threat modeling framework for AI systems. Sigstore provides a keyless signing infrastructure, and the model-signing project extends signing capabilities to ML model artifacts specifically. SLSA, Atlas CLI, and in-toto provide attestation, provenance and lineage frameworks that can provide a basis for Level 2 and Level 3 implementations. Community-contributed implementation guides and reference architectures will become available through the CoSAI WSI repository and related community channels.

11. Conclusion

Most AI models today traverse their supply chains unsigned, unverified, and untraceable. This paper presents the Artifact Integrity Maturity Model (AIMM), a structured path from baseline integrity to comprehensive attestation and policy enforcement, organized around three maturity levels that address progressively deeper trust questions.

AIMM Level 1 closes the most fundamental gap: confirming that a model is exactly the artifact the producer intended to distribute. Level 2 adds verifiable provenance and lineage, enabling organizations to trace artifacts through multi-party supply chains and respond rapidly when upstream vulnerabilities surface. Level 3 introduces trust-by-evidence: structured attestations, automated policy evaluation, and admission gating that can block non-compliant artifacts before they reach production. Each AIMM level is a legitimate destination based on organizational risk and regulatory context, not a waypoint to the next.

Runtime behavioral threats, training-time attacks, and compromised infrastructure remain outside the scope of what model signing and attestation can guarantee. AIMM is one essential layer in a defense-in-depth strategy, not a substitute for behavioral testing, runtime monitoring, or independent audits.

CoSAI Workstream 1 will continue to evolve AIMM through community collaboration, with a focus on lowering adoption barriers through companion implementation guides and reference tooling. Organizations that invest in foundational signing capabilities now will be well positioned to meet the governance demands already emerging across regulatory frameworks worldwide.

12. Sources

- [1] C2PA Technical Specification
- [2] IETF RFC 9334
- [3] in-toto Attestation Framework
- [4] ISO/IEC 27000:2024
- [5] NIST SP 800-207 Zero Trust Architecture
- [6] NIST FIPS 186-5, Digital Signature Standard
- [7] NIST SP 800-53 Rev. 5, Security and Privacy Controls for Information Systems and Organizations
- [8] NIST SP 800-218A, Secure Software Development Practices for Generative AI and Dual-Use
- [9] SLSA Specification v1.2
- [10] CoSAI WS1, Signing ML Artifacts

13. Contributors and Acknowledgements

Workstream Leads

- Asmae Mhassni, Intel asmae.mhassni@intel.com
- Matt Maloney, Cohere mattmaloney@cohere.com
- Jay White, Microsoft jaywhite@microsoft.com

Editors

- Asmae Mhassni, Intel asmae.mhassni@intel.com
- Matt Maloney, Cohere mattmaloney@cohere.com
- Jay White, Microsoft jaywhite@microsoft.com
- Marcela Melara, Intel marcela.melara@intel.com

- Arbër Salihi, Thomson Reuters arber.salihi@thomsonreuters.com

Contributors

- Andre Elizondo, Wiz
- Arbër Salihi, Thomson Reuters arber.salihi@thomsonreuters.com
- Bill Stout bstout@thealliance.ai
- Daniel Rohrer, NVIDIA drohrer@nvidia.com
- David Pierce, Paypal davpierce@paypal.com
- Jigisha Mavani, IBM jigisha.mavani@ibm.com
- Marcela Melara, Intel marcela.melara@intel.com
- Mihai Maruseac, OpenAI
- Ralph Bean, Red Hat rbean@redhat.com
- Rithikha Rajamohan, EQTY Lab rithikha.rajamohan@eqtylab.io

Technical Steering Committee Co-Chairs

- Akila Srinivasan, Anthropic akila@anthropic.com
- J.R. Rao, IBM jrrao@us.ibm.com

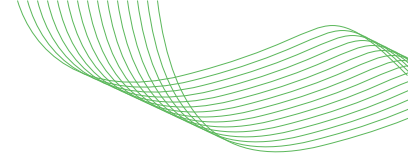
14. Appendix

14.1 CoSAI Focus

CoSAI is an OASIS Open Project, bringing together an open ecosystem of AI and security experts from industry-leading organizations. The project is dedicated to sharing best practices for secure AI deployment and collaborating on AI security research and product development. The scope of CoSAI is specifically focused on the secure building, integration, deployment, and operation of AI systems, with an emphasis on mitigating security risks unique to AI technologies. Other aspects of Trustworthy AI are deemed important but beyond the scope of the project including, ethics, fairness, explainability, bias detection, safety, consumer privacy, misinformation, hallucinations, deep fakes, or content safety concerns like hateful or abusive content, malware, or phishing generation. By concentrating on developing robust measures, best practices, and guidelines to safeguard AI systems against unauthorized access, tampering, or misuse, CoSAI aims to contribute to the responsible development and deployment of resilient, secure AI technologies.

14.2 Guidelines on usage of more advanced AI systems (e.g. large language models (LLMs), multi-modal language models. etc) for drafting documents for OASIS CoSAI:

tl;dr: CoSAI contributions are actions performed by humans, who are responsible for the content of those contributions, based on their signed OASIS iCLA (and eCLA, if applicable). [Each contributor must confirm whether they are entitled to donate that material under the applicable open source license; OASIS and the CoSAI Project do not separately confirm that.] Each contributor is responsible for ensuring that all contributions comply with these AI use guidelines, including disclosure of any use of AI in contributions.



- Selection of AI systems: CoSAI recommends the use of reputable AI systems (lowering the risk of inadvertently incorporating infringing material).
- Model constraints: Currently, CoSAI or OASIS are not required to have a contract or financial agreement for using AI systems from specific vendors. However, CoSAI editors should consider employing varying tools to avoid potential fairness concerns among vendors.
- IP infringement: It is the responsibility of the individual who subscribes/prompts and receives a response from an AI system to confirm they have the right to repost and donate the content to OASIS under our rules.
- Transparency: CoSAI's goal will be to maintain transparency throughout the process by documenting substantial use of AI systems whenever possible (e.g., the prompts and the AI system used), and to ensure that all content, regardless of production by human or AI systems, was reviewed and edited by human experts. This helps build trust in the standards development process and ensures accountability.
- Human-edited content and quality control: CoSAI mandates human-reviewed or -edited results for any final outputs. A robust quality control process should be in place, involving careful review of the generated content for accuracy, relevance, and alignment with CoSAI's goals and principles. Human experts should scrutinize the output of AI systems to identify any errors, inconsistencies, or potential biases.
- Iterative refinement: The use of AI systems in drafting standards should be seen as an iterative process, with the generated content serving as a starting point for further refinement and improvement by human experts. Multiple rounds of review and editing may be necessary to ensure the final standards meet the required quality and reliability thresholds.

14.3 Disclaimer

The views represented in this paper do not necessarily represent the views of all CoSAI members, including reviewers and their organizations.

14.4 Copyright Notice

Copyright © OASIS Open 2026. All Rights Reserved. This document has been produced under the process and license terms stated in the OASIS Open Project rules: <https://www.oasis-open.org/policies-guidelines/open-projects-process>.

This document and translations of it may be copied and furnished to others, and derivative works that comment on or otherwise explain it or assist in its implementation may be prepared, copied, published, and distributed, in whole or in part, without restriction of any kind, provided that the above copyright notice and this section are included on all such copies and derivative works. The limited permissions granted above are perpetual and will not be revoked by OASIS or its successors or assigns. This document and the information contained herein is provided on an "AS IS" basis and OASIS DISCLAIMS ALL WARRANTIES, EXPRESS OR IMPLIED, INCLUDING BUT NOT LIMITED TO ANY WARRANTY THAT THE USE OF THE INFORMATION HEREIN WILL NOT INFRINGE ANY OWNERSHIP RIGHTS OR ANY IMPLIED WARRANTIES OF MERCHANTABILITY OR FITNESS FOR A PARTICULAR PURPOSE. OASIS AND ITS MEMBERS WILL NOT BE LIABLE FOR ANY DIRECT, INDIRECT, SPECIAL OR CONSEQUENTIAL DAMAGES ARISING OUT OF ANY USE OF THIS DOCUMENT OR ANY PART THEREOF. The name "OASIS" is a trademark of OASIS, the owner and developer of this document, and should be used only to refer to the organization and its official outputs. OASIS welcomes reference to, and implementation and use of, documents, while reserving the right to enforce its marks against misleading uses. Please see <https://www.oasis-open.org/policies-guidelines/trademark/> for above guidance.

This is a Non-Standards Track Work Product. The patent provisions of the OASIS IPR Policy do not apply.

07 September 2026 Non-Standards Track Copyright © OASIS Open 2026\, All Rights Reserved.
Page 2 of 10 This document was last revised or approved by the CoSAI Open Project on the above date.